Assignment 2: Analysis of Competing Hypotheses: Aurora Biotech Labs

Clement Ampofo · CIS*6530 Cyber Threat Intelligence and Adversarial Risk Analysis · Deliverable 2.1: ACH Matrix

Key: C = Consistent · I = Inconsistent · NA = Not applicable / diagnostic-neutral. Rows 1–11 are scenario evidence (all retained). Row E12 (shaded yellow) and assumptions A1–A4 are the student's own additions, not scenario facts. Most diagnostic items: **6**, **9**, and **4/E12** (see report §3). Items consistent with all or nearly all hypotheses (7, 8, 1, 10, 11) confirm very little.

Evidence item	H1 State-linked espionage	H2 Independent insider	H3 Cybercriminal intrusion	H4 Benign / false alarm	H5 Competitor-directed insider (added)	Justification / notes
1. Bulk download then resignation	C	C	NA	C	C	Pre-departure collection fits every theft hypothesis, and a scientist taking a copy of her own work before leaving also fits H4. H3 says the resignation is a coincidence, so it neither predicts nor rules out this item. Weakly diagnostic on its own.
2. New RAT, foreign IP range	C	NA	C	C	NA	H4 rated C on purpose: by itself, an unapproved remote tool calling overseas could be shadow IT (for example, a researcher working with overseas collaborators). Item 6 is what rules that out. H2 and H5 say nothing about the tool, so NA.
3. Targeted phishing campaign	C	NA	C	I	NA	H4 rated I: the credentials were used from a never-before-seen device two days after the email was opened, which goes against 'the phishing email was not acted on maliciously' (assumption A4: the device has not been verified as a new personal device). Spear-phishing senior scientists with a journal-portal lure fits both H1 and H3.
4. DLP alert, personal cloud upload	C	C	I	C	C	H3 rated I: criminals send stolen data to infrastructure they control, not to an employee's named personal cloud account on her own workstation. H4 rated C because the scenario itself gives a 'policy-violating personal backup habit' as a possible innocent explanation, which item 9 then undermines.
5. No extortion contact or leak-site activity	C	C	I	C	C	Only H3 predicts extortion or resale. The I is soft: this is absence of evidence over a short window, and some criminals hold data or sell it quietly. Espionage actors and insiders do not normally extort.
6. C2 infrastructure overlap with known APT	C	NA	I	I	NA	Most diagnostic item for the technical side. It is the only item that says who runs the RAT, and it contradicts both a criminal operator (H3) and an innocent tool (H4). Caveat: one SSL-certificate match, attributed with moderate confidence by a second vendor, and certificates can be shared, reused, or planted as a false flag. H2 and H5 do not address the RAT, so NA.
7. Counteroffer from an overseas competitor	C	C	NA	C	C	Feels incriminating but discriminates almost nothing. Moving to a rival is ordinary (H4), a career step (H2), a recruitment route (H1), and the beneficiary under H5. 'Same general region' is too vague to tie the firm to item 2. Close to non-diagnostic.
8. Misconfigured access control (ACL)	C	C	NA	C	C	An enabling condition that explains how she reached the files, not why. The ACL fault started about six weeks ago, before the phishing (about three weeks), so the intruder did not create it. Non-diagnostic.
9. Content mix of downloaded files (60/40)	C	C	NA	I	C	Most diagnostic item for the insider side. H4 rated I: a personal backup of her own work would not include another project's manufacturing-cost and supply-chain files. H2 rated C only because H2 covers data 'useful at her new employer'; commercial cost data from someone else's project fits directed collection (H1, H5) more naturally than career self-interest. H3 does not involve her download, so NA.
10. No other compromised accounts	C	C	I	C	C	A small footprint (one phished account plus the insider) fits a low-and-slow APT and also a lone insider. H3 rated I (soft): double-extortion crews usually move laterally and escalate privileges before stealing data. H4 rated C because 'nothing widespread' is what a false alarm looks like. The phished account's anomaly was already counted under item 3.

Evidence item	H1 State-linked espionage	H2 Independent insider	H3 Cybercriminal intrusion	H4 Benign / false alarm	H5 Competitor-directed insider (added)	Justification / notes
11. Sector-wide phishing wave (ISAC advisory)	**C**	**NA**	**C**	**C**	**NA**	Consistent with H1, H3 and H4 (Aurora caught up in a broad wave), so it confirms little. It also lowers the weight of item 3: Aurora was probably not singled out, which makes the timing of the phishing next to the resignation more plausibly coincidental.
E12 [ADDED, derived inference from items 2+4]: Exfiltration channel divergence: insider data left through a DLP-visible personal cloud account, not through the RAT/C2 channel already in the division	**I**	**C**	**NA**	**C**	**C**	Student's own derived row, not a scenario fact. H1 rated I only against its coordinated-insider version: a state service with a working implant in the division would not usually have its asset upload through a traceable personal account. The I is soft, because services sometimes keep insiders and implants separate on purpose. H3 rated NA to avoid counting item 4 twice.
Inconsistency tally (count of I ratings)	**1**	**0**	**4**	**3**	**0**	**The tally informs but does not decide. H2 and H5 reach 0 partly because they are NA on the four technical items they do not explain. H4's three Is carry more weight than H3's four.**

Student-added assumptions (not scenario facts):

- **A1 [ADDED, student assumption]:** The workstation hosting the RAT (item 2) is *not* confirmed to be the resigning scientist's; the scenario says only “the same research division.” Treated as unknown.
- **A2 [ADDED, student assumption]:** The phished scientist (item 3) and the resigning scientist (item 1) are two different people, as item 10 lists them as two separate anomalous accounts.
- **A3 [ADDED, student assumption]:** Reconstructed timeline (day 0 = first evening of bulk download): ACL misconfigured from ~day −42; phishing ~day −21; phished credentials reused ~day −19; RAT installed ~day −10; download days 0–1; resignation ~day 3. The ACL fault therefore predates the intrusion.
- **A4 [ADDED, student assumption]:** The “previously unseen device” in item 3 has not been verified as a new personal device of the phished scientist; if it were, the H4 rating on item 3 would soften to C.

Deliverable 2.2: Analytic Report

Clement Ampofo · CIS*6530 · Assignment 2

> **Word count: 1,567** (body text only; excludes the ACH matrix, section headers, and this line)

1. Key judgment

The evidence best supports a compound explanation: the resigning scientist deliberately stole intellectual property (**high confidence**, which rejects H4), while a separate remote-access intrusion is more likely state-linked espionage, the technical part of H1, than cybercrime (**moderate confidence**). The question that matters most, whether that actor directed the insider, I can answer only with **low confidence**. On current evidence the two activities look concurrent rather than coordinated, so an insider acting alone (H2) or for a competitor (H5) is somewhat more likely than a fully coordinated H1 operation.

2. Hypothesis set

- **H1, state-linked economic espionage:** a state-linked or state-tolerated actor is acquiring Aurora's IP for its state's pharmaceutical sector, by intrusion, a co-opted insider, or both.
- **H2, independent insider:** the scientist, acting on her own initiative, is taking data she believes will help her at her new employer.
- **H3, financially motivated cybercriminals:** a criminal group got in through the phishing to steal data for extortion or resale. The resignation is coincidental.
- **H4, benign or false alarm:** each signal has an innocent explanation and no IP was stolen.
- **H5 (added), competitor-directed commercial espionage:** the rival firm, acting for its own commercial benefit and without state direction, induced or tasked the scientist during her recruitment to bring specific Aurora data, including manufacturing and supply-chain information. The remote-access intrusion is unrelated.

H5 is genuinely distinct because it changes who decides what is taken. Unlike H2, the collection is directed from outside. Unlike H1, the director is a private company with corporate rather than state goals. It therefore predicts different things: contact with the rival before the formal offer, collection matched to the rival's commercial gaps, and no link to the APT infrastructure.

3. Evidence and diagnosticity

The matrix splits into two clusters. The insider cluster is items 1, 4, 7, 8 and 9. The technical cluster is items 2, 3, 6, 10 and 11. Item 5 bears on both. The most important pattern is how few items discriminate at all. Most rows are Consistent with three or four hypotheses, so they confirm almost nothing. Three items do most of the analytic work.

Item 6 (C2 certificate overlap) is the most diagnostic item for the technical cluster. Without it, items 2 and 3 fit H1, H3, and even H4: an unapproved remote tool can be shadow IT, and a login from a new device can be a new phone. Item 6 is the only evidence about *who* operates the tool. It links the tool to an actor

known for stealing biotech IP, which makes it Inconsistent with both a criminal operator and an innocent explanation. Its weakness is that H1's technical claim rests almost entirely on it. It is a single certificate match, attributed second-hand and with moderate confidence by a different vendor, and certificates and hosting get reused, shared, and occasionally planted as false flags. That single point of failure is why my judgment on the technical cluster is moderate rather than high.

Item 9 (60/40 file mix) is the most diagnostic item for the insider cluster. A personal backup would contain her own project's files. Forty percent of the download belonged to a different drug candidate, and those files were manufacturing-cost and supply-chain records: commercial information, not scientific. That makes item 9 decisively Inconsistent with H4. It is also the only evidence about what the collector actually wanted. A scientist advancing her own career would value her own research, the 60%. Cost and supply-chain data matter to a business competing with Aurora, or to a state supporting such businesses. So item 9 fits H2 only loosely, through H2's "useful at her new employer" wording, and fits H1 and H5 more naturally. There is an important caveat from item 8: she reached those files through an accidental ACL fault. Grabbing whatever happened to be reachable is a real alternative to a shopping list. Item 9 rules out H4 and tilts toward directed collection without settling the question.

Item 4 (personal cloud upload), together with my derived row E12, is the third discriminator. Criminals send stolen data to their own infrastructure, not to an employee's named account, so item 4 counts against H3. More importantly, it shows the two channels diverging. If the actor running the RAT were also running her, it already had a covert channel inside her division. Having its asset upload through a traceable personal account that DLP flagged would be poor tradecraft for a state service. This is not conclusive: handlers sometimes keep insiders and implants separate on purpose, and inexperienced assets make mistakes. But it is the only evidence that bears directly on coordination, and it points away from it.

Several items are weak despite how they look. Item 7 feels like the most incriminating fact, a rival firm in the same region as the IP addresses, yet it is Consistent with H1, H2, H4 and H5. Resigning to join a rival is ordinary, and "same general region" is too vague to tie the firm to item 2. Items 1, 8 and 10 are similarly Consistent with almost everything. Item 11 actually lowers the weight of item 3: the phishing was part of a regional wave across the sector, so Aurora was probably not singled out. That fits an APT or criminals equally, and it makes the closeness in time between the phishing and the resignation more plausibly coincidental. Item 5 discriminates only against H3, and it is absence of evidence over a short window.

4. Inconsistencies and what they rule out (or don't)

The tallies are H1 = 1, H2 = 0, H3 = 4, H4 = 3, H5 = 0. Read literally, H2 and H5 lead. That is an artifact of the method. Both explain only the insider cluster and are rated NA on items 2, 3, 6 and 11 because they say nothing about the RAT. Zero inconsistencies means "nothing here contradicts it," not "it explains everything." Any complete account built on H2 or H5 still needs a second actor for the intrusion. H1's low count partly reflects how broad it is: an actor using "intrusion, an insider, or both" is hard to contradict. Its one inconsistency (E12) falls on the coordinated-insider version specifically, which is the version that would justify treating the scientist as a state agent.

H4 has fewer inconsistencies than H3 but is the more firmly disqualified, because its three inconsistencies are independent and carry heavy weight. Item 3's credential reuse could just about be explained away as a

new device. Item 6 could just about be a mistaken attribution. Item 9, however, cannot be explained by a backup habit, and on its own it disqualifies H4 for the insider cluster. A benign reading of the technical cluster survives only if item 6 collapses *and* the unseen device turns out to be innocent, and I judge that unlikely.

H3's four inconsistencies (items 4, 5, 6 and 10) are each softer. Criminals sometimes sit on data or sell it quietly, so item 5 is weak. A small footprint is unusual for them but not impossible (item 10). Item 6 is a moderate-confidence attribution, and criminals do share infrastructure. Taken together, though, they add up, and no item favors H3 over H1: items 2, 3 and 11 fit both equally. H3 is therefore unlikely but not excluded. It is the leading alternative for the technical cluster if item 6 fails.

5. Conclusion, confidence, and what would change my mind

My final judgment is a compound one. With high confidence, the scientist deliberately removed Aurora IP, including data outside her own project. With moderate confidence, the RAT activity is state-linked espionage rather than criminal. With low confidence, the two are not coordinated. An independent insider (H2) or a competitor-directed one (H5) is marginally favored over a coordinated H1, and no current evidence separates H2 from H5. I am not claiming that she is a state agent, and I am not claiming that the events are definitely unrelated. The evidence runs out at what the phished account and the RAT actually accessed, and nothing in the scenario reports that.

Sensitivity. The single most consequential new fact would be any forensic link between the RAT and the resigning scientist. That could be the tool running on her own workstation, her credentials being used through it, or the files she downloaded appearing in its traffic. If such a link exists, coordinated H1 becomes the leading hypothesis at moderate-to-high confidence and the case becomes a state-espionage counterintelligence matter. If the RAT host turns out to belong to the phished scientist and shows no contact with her data, my judgment that the activities are concurrent but separate grows stronger. A close second: if item 6's attribution is withdrawn, or the certificate proves to be shared commodity hosting, the technical cluster falls to low confidence between H1 and H3.

Indicators to monitor.

- **Infrastructure:** any further connections to the item-2 IP ranges or the matched certificate fingerprint, shared through the ISAC. If other members see the same infrastructure, that points to a sector-wide APT campaign rather than one aimed at Aurora.
- **Access logs:** repository logs for the phished account and the roughly 40 ACL-exposed users, to establish exactly what the intruder reached.
- **Criminal markets:** continued leak-site and marketplace monitoring for 60–90 days. A delayed extortion demand would revive H3.
- **The rival firm:** patent filings, trial registrations, or manufacturing and supplier changes that resemble the second candidate's cost and supply-chain data, plus any evidence of contact with the scientist before the offer. Either would favor H5 or H1 over H2, which does not predict quick corporate use of commercial data.